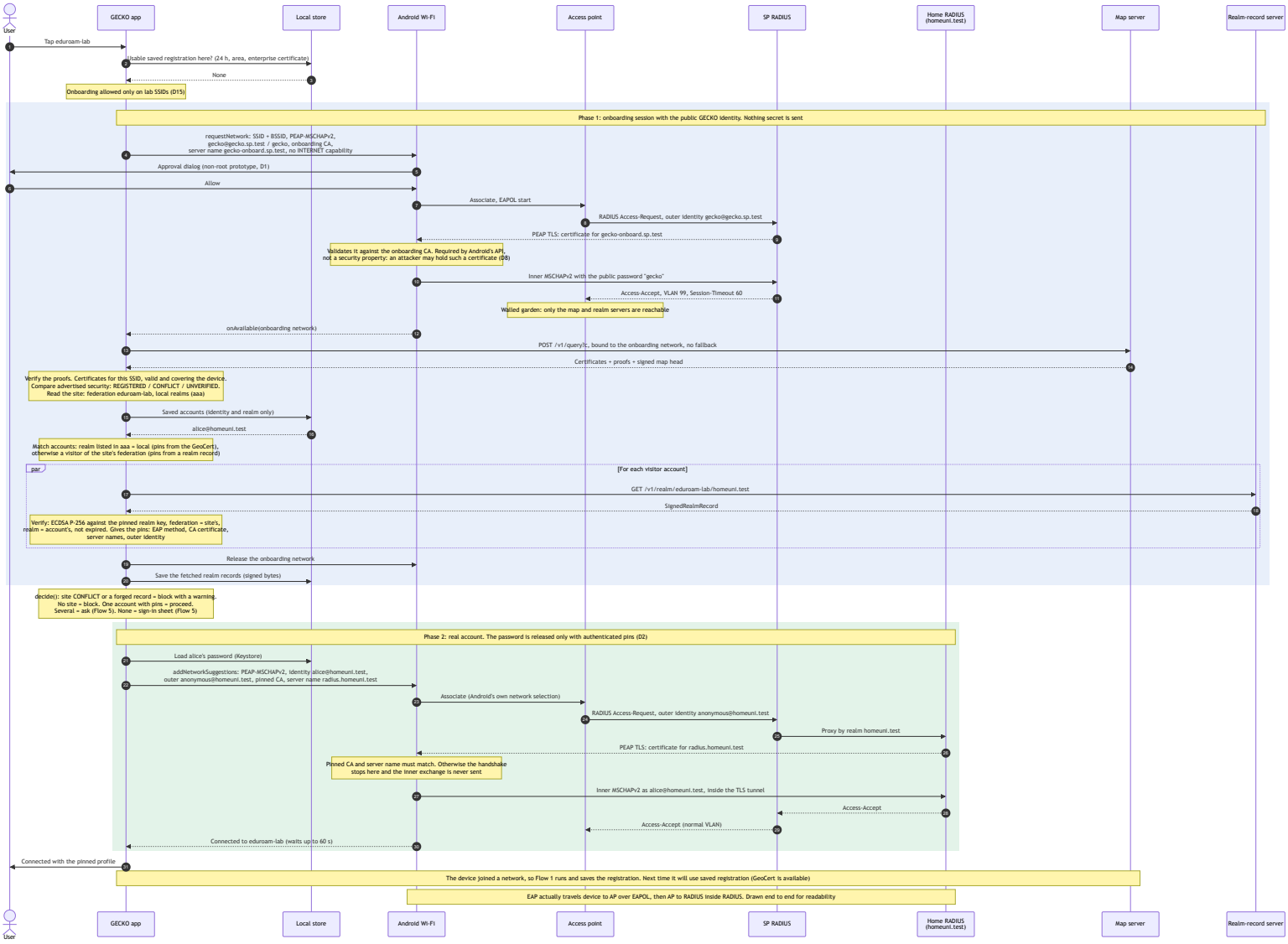

User
GECKO app
Local store
Android Wi-Fi
Access point
SP RADIUS
Home RADIUS (homeuni.test)
Map server
Realm-record server
1 Tap eduroam-lab
2 Usable saved registration here? (24 h, area, enterprise certificate)
3 None
Onboarding allowed only on lab SSIDs (D15)
Phase 1: onboarding session with the public GECKO identity. Nothing secret is sent
4 requestNetwork: SSID + BSSID, PEAP-MSCHAPv2, gecko@gecko.sp.test / gecko, onboarding CA, server name gecko-onboard.sp.test, no INTERNET capability
5 Approval dialog (non-root prototype, D1)
6 Allow
7 Associate, EAPOL start
8 RADIUS Access-Request, outer identity gecko@gecko.sp.test
9 PEAP TLS: certificate for gecko-onboard.sp.test
Validates it against the onboarding CA. Required by Android's API, not a security property: an attacker may hold such a certificate (D8)
10 Inner MSCHAPv2 with the public password "gecko"
11 Access-Accept, VLAN 99, Session-Timeout 60
Walled garden: only the map and realm servers are reachable
12 onAvailable(onboarding network)
13 POST /v1/query?c, bound to the onboarding network, no fallback
14 Certificates + proofs + signed map head
Verify the proofs. Certificates for this SSID, valid and covering the device. Compare advertised security: REGISTERED / CONFLICT / UNVERIFIED. Read the site: federation eduroam-lab, local realms (aaa)
15 Saved accounts (identity and realm only)
16 alice@homeuni.test
Match accounts: realm listed in aaa = local (pins from the GeoCert), otherwise a visitor of the site's federation (pins from a realm record)
par
[For each visitor account]
17 GET /v1/realm/eduroam-lab/homeuni.test
18 SignedRealmRecord
Verify: ECDSA P-256 against the pinned realm key, federation = site's, realm = account's, not expired. Gives the pins: EAP method, CA certificate, server names, outer identity
19 Release the onboarding network
20 Save the fetched realm records (signed bytes)
decide(): site CONFLICT or a forged record = block with a warning. No site = block. One account with pins = proceed. Several = ask (Flow 5). None = sign-in sheet (Flow 5)
Phase 2: real account. The password is released only with authenticated pins (D2)
21 Load alice's password (Keystore)
22 addNetworkSuggestions: PEAP-MSCHAPv2, identity alice@homeuni.test, outer anonymous@homeuni.test, pinned CA, server name radius.homeuni.test
23 Associate (Android's own network selection)
24 RADIUS Access-Request, outer identity anonymous@homeuni.test
25 Proxy by realm homeuni.test
26 PEAP TLS: certificate for radius.homeuni.test
Pinned CA and server name must match. Otherwise the handshake stops here and the inner exchange is never sent
27 Inner MSCHAPv2 as alice@homeuni.test., inside the TLS tunnel
28 Access-Accept
29 Access-Accept (normal VLAN)
30 Connected to eduroam-lab (waits up to 60 s)
31 Connected with the pinned profile
The device joined a network, so Flow 1 runs and saves the registration. Next time it will use saved registration (GeoCert is available)
EAP actually travels device to AP over EAPOL, then AP to RADIUS inside RADIUS. Drawn end to end for readability